# Posture and monitoring

Posture management tells you what is wrong. Workload protection tells you what is happening. Exposure management shows what an attacker sees.

**SC-500 Academy posters**
Front: Defender for Cloud
Checked against Microsoft Learn on 20 October 2026

## Foundational CSPM or Defender CSPM? 4.1.1

| Capability | Foundational (free) | Defender CSPM |
|---|---|---|
| Recommendations, secure score, inventory | **Yes** | **Yes** |
| Microsoft cloud security benchmark | **Yes** | **Yes** |
| Other regulatory standards | Needs a paid plan | **Yes** |
| Governance rules (owner, due date) | No | **Yes** |
| Cloud security explorer | No | **Yes** |
| Attack path analysis | No | **Yes** |
| Agentless scanning for machines | No | **Yes** |
| Risk prioritisation, AI security posture | No | **Yes** |

- **Enable Defender CSPM as Subscription Owner.** Anyone else can switch it on, but agentless scanning isn't enabled, so attack paths and the explorer lack vulnerability data.
- Classic secure score (Azure portal) tracks benchmark controls; the Defender portal's Cloud Secure Score is risk-weighted. Neither is an attack path, which is a chain: exposure + vulnerability + identity + something valuable.

## Regulatory compliance 4.1.2 1.3.2

**Standard** an Azure Policy initiative → **Controls** → **Recommendations** → **Your resources**

- The benchmark is assigned by default. Other standards need any paid plan **except Servers Plan 1 or APIs Plan 1**.
- Adding a standard: Microsoft's pages name different roles (Policy Contributor; Resource Policy Contributor plus Security Admin). Owner satisfies both.
- Accepted risk: a **waiver exemption** (expiry optional), not removing the resource from scope.
- The dashboard shows how your resources score against a framework. It is not an audit report.

## DevOps security 1.3.9 4.1.1

- Connect **Azure DevOps, GitHub or GitLab** in Environment settings.
- Microsoft Security DevOps runs scanners, including infrastructure-as-code checks, in the pipeline.
- **Pull request annotations** and code-to-cloud mapping need Defender CSPM.
- DevOps recommendations do not affect the secure score.
- A Deny policy still stops a non-compliant template at deployment, whichever tool sends it.

## Workload protection plans 4.1.3

| Plan | What it adds | Watch for |
|---|---|---|
| Servers Plan 1 | Defender for Endpoint (EDR), vulnerability assessment | Can be enabled per resource |
| Servers Plan 2 | Plan 1 + premium vulnerability management, agentless scanning with malware scanning, file integrity monitoring, JIT, OS configuration assessment, free security-data ingestion | FIM is off until you turn it on |
| Containers | Posture, image vulnerabilities, runtime threats, admission control, binary drift | Absorbed Defender for Kubernetes and for Container Registries |
| Storage | Activity alerts, on-upload malware scanning, sensitive data threat detection | Malware scanning stops at the monthly cap |
| Databases | Four types: Azure SQL, SQL servers on machines, open-source relational, Cosmos DB | One switch turns on all four; deselect any you do not want |
| Key Vault, Resource Manager | Unusual access to vaults; suspicious control-plane operations | Legacy plans deprecated; fixed pricing model |
| App Service, APIs | Attacks on web apps; API inventory and threats | APIs Plan 1 does not unlock standards |
| AI services | Runtime alerts on prompts and responses | Discovery comes from Defender CSPM |

- All are **off by default**, enabled per subscription (some per resource). Deleting a lab resource group leaves a subscription plan on.
- **Deploy them with Azure Policy at a management group** so new subscriptions inherit them.

## Anatomy of an attack path 4.1.1

**Internet exposure** open port, public IP → **Vulnerable machine** critical CVE → **Its identity** managed identity → **Its permissions** role on a storage account → **Sensitive data**

- Each box alone is one recommendation among thousands. **The chain is one prioritised finding.**
- **Cloud security explorer** queries the same graph directly: "internet-facing VMs with a critical vulnerability and access to sensitive data" is one query.
- The graph is fed by agentless scanning, Defender Vulnerability Management, container image scanning, secret scanning and data classification. Missing inputs mean missing paths.

## Which plan raises that alert? 4.1.1 4.1.3

| | |
|---|---|
| *"malware uploaded to a blob"* | → **Defender for Storage** |
| *"SQL injection attempt on Azure SQL"* | → **Defender for Databases (Azure SQL)** |
| *"unusual access to a key vault"* | → **Defender for Key Vault** |
| *"suspicious ARM operations from a new location"* | → **Defender for Resource Manager** |
| *"crypto-mining process on a VM"* | → **Defender for Servers (Defender for Endpoint)** |
| *"a binary that was not in the container image"* | → **Defender for Containers** |
| *"jailbreak attempt against an Azure OpenAI deployment"* | → **Defender for AI Services** |
| *"internet-exposed VM with a critical CVE"* | → **No alert: a Defender CSPM attack path** |

## Multicloud, vulnerabilities and attack surface 4.1.4 4.1.5 4.1.6

- **AWS and GCP**: security connectors in Environment settings. Azure Arc auto-provisioning gives their machines the full Defender for Servers feature set; decline it and agentless scanning still covers them, but Arc-dependent features do not.
- **Defender Vulnerability Management** for Azure VMs: through the Defender for Endpoint extension (on by default with a Servers plan) or agentless disk scanning. CMK-encrypted disks need Key Vault permissions first.
- **Defender EASM** looks from the outside, from seeds: domains, IP blocks, ASNs. Its own Azure resource and bill: 30-day trial, then billed per asset in **Approved Inventory**.

| EASM state | Meaning |
|---|---|
| Approved Inventory | Yours. Scanned daily. Billed |
| Candidate, Requires Investigation | Weak link to you. Review it |
| Dependency | Third-party infrastructure you rely on |
| Monitor Only | Related, not owned; kept separate for reporting |

## Defender for Servers: Plan 1 or Plan 2 3.2.6 3.2.7 4.1.5

| Capability | Plan 1 | Plan 2 |
|---|---|---|
| Defender for Endpoint (EDR) | **Yes** | **Yes** |
| Vulnerability assessment | **Yes** | **Yes**, premium |
| Agentless scanning: vulnerabilities, secrets | No | **Yes** |
| Agentless malware scanning | No | **Yes** |
| File integrity monitoring | No | **Yes**, off until enabled |
| Just-in-time VM access | No | **Yes** |
| OS configuration assessment | No | **Yes** |
| Free ingestion: 500 MB a day per machine, pooled; eligible security tables; Plan 2 on the workspace | No | **Yes** |

- Agentless scanning snapshots disks about **every 24 hours**, and only on **running** machines. Disks encrypted with customer-managed keys need Key Vault permissions first.
- Defender CSPM also includes agentless scanning for vulnerabilities and secrets.



Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

# Posture and monitoring

Collect only what detections and investigations need, keep it as long as the questions demand, and automate the routing.

**SC-500 Academy posters**
Back: Sentinel, Purview Audit and Security Copilot
Checked against Microsoft Learn on 20 October 2026

## How data reaches Sentinel

4.2.4 4.2.5 4.2.6 4.2.7

**Source** → **Connector or Azure Monitor Agent** → **Data collection rule** filter, transform →

**Table** → **Analytics tier** rules, hunting → **Data lake** long retention

| Source | Path | Lands in |
|---|---|---|
| Azure activity, Entra ID | Microsoft data connectors | AzureActivity, SigninLogs, AuditLogs |
| Defender XDR | On automatically when the workspace joins the Defender portal | Alerts, incidents, advanced hunting tables |
| Firewalls and appliances (CEF) | Syslog to a Linux forwarder with AMA | CommonSecurityLog |
| Linux syslog | AMA, syslog data collection rule | Syslog |
| Windows Security log | AMA; event set or custom XPath | SecurityEvent |
| Windows Event Forwarding | Collector with AMA, Forwarded Events | **WindowsEvent** |
| Anything else | Logs Ingestion API, DCR-based custom table | Name_CL |

- The Defender XDR connector disconnects the per-product alert connectors itself and its alerts are free. Turn off Microsoft incident creation rules, or each alert raises two incidents.
- Windows machines outside Azure need **Azure Arc** before the Azure Monitor Agent.
- A connector that says Connected but shows no recent data is the failure to recognise. Check the Usage table.

## Workspaces, roles and content

4.2.1 4.2.2 4.2.3

| Role | Can |
|---|---|
| Microsoft Sentinel Reader | View data, incidents, workbooks |
| Microsoft Sentinel Responder | Also manage incidents |
| Microsoft Sentinel Contributor | Also create and edit content, such as analytics rules |
| Automation Contributor | For Sentinel itself: run playbooks |
| Playbook Operator | Run playbooks manually |
| Logic App Contributor | Build playbooks; no Sentinel role grants this |

- One workspace unless a real reason splits it: data residency, separate tenants, billing.
- Sentinel in the Azure portal retires on **31 March 2027**; it lives in the Defender portal, with a primary workspace.
- **Content hub** solutions deliver templates. Nothing detects until you create rules from them.

## Automation and retention

4.2.8 4.2.9

| | Automation rule | Playbook |
|---|---|---|
| Is | Routing logic in Sentinel | A Logic App |
| Does | Assign, tag, change status, suppress until a date, run a playbook | Act in other systems |
| Needs | Sentinel Contributor | Automation Contributor for Sentinel + its own identity's roles |

| Retention | Detail |
|---|---|
| Analytics tier | 30 days by default; Sentinel solution tables extend to 90 days at no charge, any table to two years. Rules and hunting see it |
| Data lake tier | Up to 12 years of total retention, at lower cost. Search jobs, KQL jobs, notebooks |
| Changing it | Shorter total retention: data kept 30 more days so you can revert. Analytics retention changes apply at once |

## Tables you should recognise

4.2.4 4.2.6 4.2.7

| Table | Holds |
|---|---|
| SigninLogs, AuditLogs | Entra sign-ins and directory changes |
| AzureActivity | Azure control-plane operations |
| SecurityEvent | Windows Security events collected directly |
| WindowsEvent | Windows events forwarded through WEF |
| CommonSecurityLog | CEF from firewalls and appliances |
| Syslog | Linux and plain syslog |
| SecurityAlert, SecurityIncident | Alerts and incidents |
| Name_CL | Your custom tables |
| Usage | What was ingested, by table: the cost and health check |

## Sentinel in the Defender portal

4.2.1 4.2.2

- Onboarding sets a **primary workspace**; more workspaces can join. It needs Security Administrator in Entra ID, plus Owner (unconditional, at the subscription) or User Access Administrator with Microsoft Sentinel Contributor.
- The **Defender XDR connector** turns on automatically when the workspace joins.
- **GDAP with Azure Lighthouse** is not supported for Sentinel data in the Defender portal: use Entra B2B and Defender multitenant management. Lighthouse still lets advanced hunting query other tenants' workspaces with `workspace()`.
- Content hub installs need Microsoft Sentinel Contributor on the resource group.

## Microsoft Purview Audit

4.2.10

| | Standard | Premium |
|---|---|---|
| Licence | E3, E5 and others | E5 (Advanced Auditing service plan) |
| Default retention | 180 days | 1 year for Entra ID, Exchange, OneDrive, SharePoint |
| Longer retention | No | Retention policies; up to 10 years with an add-on |
| MailItemsAccessed | **Yes** | **Yes**, with sensitivity label |
| SearchQueryInitiated | No | **Yes** |

- Search from the Defender portal Audit page or Purview: the same tool. Needs Audit Logs or View-Only Audit Logs.
- Nothing for every query? Check `UnifiedAuditLogIngestionEnabled`.

## Cost controls

4.2.1 4.2.9

- Set a **daily cap** before the first connector. When reached, collection stops: security data too.
- Filter in the **data collection rule**: what the agent never collects is never billed (XPath for Windows events; facilities and severities for syslog). Transformation filtering is free only for Analytics tables in Sentinel workspaces.
- **Commitment tiers**: raising one restarts its 31-day period; lowering waits until the period ends, except within 6 hours of a change.
- Keep verbose tables short in the analytics tier and long in the data lake.

## Microsoft Security Copilot

4.3.1 4.3.2 4.3.3 4.3.4

| Capacity | Billing |
|---|---|
| Provisioned SCUs (1 to 100) | Hourly, from the moment provisioned |
| Overage SCUs | Only when used |
| Microsoft 365 E5 or E7 | 400 SCUs a month per 1,000 licences, up to 10,000; default capacity, not billed hourly |

- Each **workspace** has its own capacity, plugins and role assignments. SCUs are not shared between workspaces.
- **Provisioning** needs Azure Owner or Contributor *and* Security Administrator.
- **Contributor** defaults to the Recommended Microsoft Security roles group. Everyone is the legacy default; once removed it cannot be re-added.
- Copilot answers with the user's own permissions. Plugins decide what it can reach; custom plugins are off for contributors by default.
- **Agents** run with an agent identity (recommended; Microsoft-built agents only) or a user account, and consume SCUs as they work.

## Security Copilot roles

4.3.2 4.3.4

| Role | Can |
|---|---|
| Copilot owner | Settings, plugins for everyone, capacity, roles |
| Copilot contributor | Use Copilot and their own plugins, within their own permissions |

- Owner is inherited by Global Administrator, Security Administrator, Billing Administrator, Entra Compliance Administrator, Intune Administrator and some Purview roles.
- Copilot roles go to users or to **role-assignable** groups.
- Buying from the Security Store needs Owner or Contributor on the Azure billing subscription.



Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.